

Relatório de Auditoria de Segurança

Collegium (Solo Learning) — Auditoria Final (v3)

Data: 28 de agosto de 2026

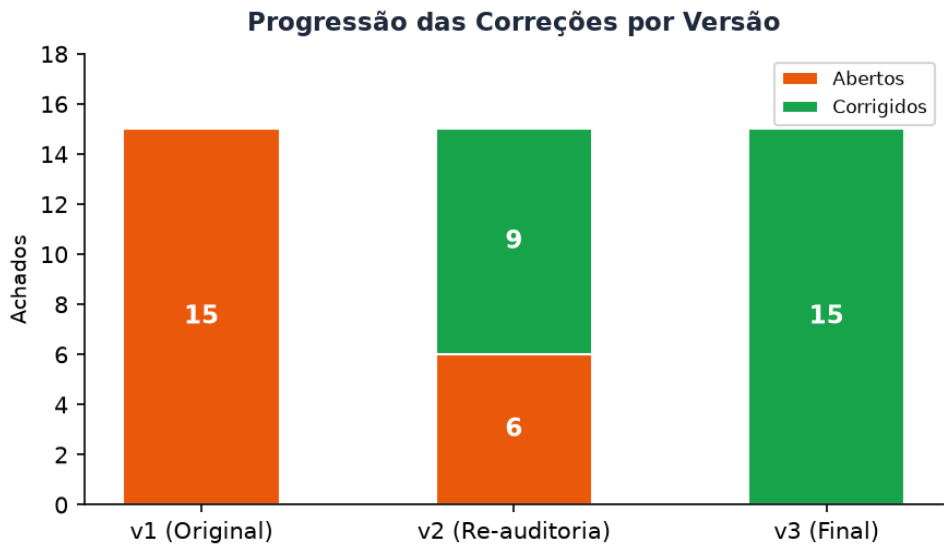
Backend (Fastify + Prisma + PostgreSQL) — Todas as correções verificadas e aprovadas

15/15 achados corrigidos

100% de resolução

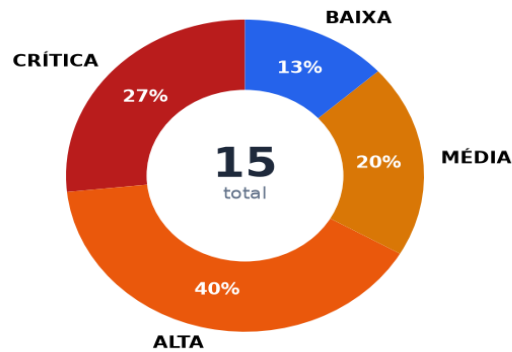
1. Resumo Executivo

Esta auditoria final verifica a totalidade dos **15 achados** identificados nas auditorias v1 e v2. Todos os achados foram corrigidos ao longo de 3 iterações de auditoria e correção.



Severidade	Total	Status
■ Crítica	4	■ Todos corrigidos
■ Alta	6	■ Todos corrigidos
■ Média	3	■ Todos corrigidos
■ Baixa	2	■ Todos corrigidos
TOTAL	15	■ 100%

Distribuição por Severidade (100% Corrigidos)



2. Todos os Achados — Correções Verificadas

Cada achado da auditoria original foi verificado individualmente. Abaixo, a evidência de correção:

■ CORRIGIDO CRED-001 CRÍTICA

JWT hardcoded fallback → validação startup

■ auth.ts:6-8

ANTES: fallback hardcoded. DEPOIS: throw se JWT_SECRET não definido.

■ CORRIGIDO CRED-003 CRÍTICA

Credenciais Docker hardcoded → variáveis de ambiente

■ docker-compose.yml:5-7

ANTES: valores inline. DEPOIS: \${POSTGRES_USER:-default}.

■ CORRIGIDO CRED-004 CRÍTICA

Senhas alunos texto plano → bcrypt hash

■ admin.ts:452,504,549

ANTES: texto plano. DEPOIS: bcrypt.hash() em todos os 3 pontos.

■ CORRIGIDO AUTH-001 CRÍTICA

Webhook billing sem auth → WEBHOOK_SECRET

■ webhooks.ts:1-20

ANTES: zero auth. DEPOIS: valida header x-webhook-secret.

■ CORRIGIDO IDOR-001 ALTA

Reatribuição cross-tenant → verificação de posse

■ admin.ts:441-460

ANTES: sem checar. DEPOIS: isSameInst check + 403 se diferente.

■ CORRIGIDO IDOR-002 ALTA

Batch students cross-tenant → verificação P2002

■ admin.ts:560-592

ANTES: sem verificação. DEPOIS: catch P2002 + check instituição.

■ CORRIGIDO IDOR-003 ALTA

Matrix audit cross-tenant → restrito a ADMIN

■ admin.ts:matrix/audit

ANTES: query params abertos. DEPOIS: só ADMIN pode usar institutionId.

■ CORRIGIDO ISOLATION-001 ALTA

Bounty active global → filtra por instituição

■ bounty.ts:123-135

ANTES: sem filtro. DEPOIS: where instituicao para não-ADMIN.

■ CORRIGIDO XSS-001 ALTA

Email HTML injection → escapeHtml()

■ bounty.ts:33-40,87-92

ANTES: sem escape. DEPOIS: escapeHtml() em todos os campos.

■ CORRIGIDO CRED-005 ALTA**Senha hardcoded arquitetos → `crypto.randomBytes`**■ `superadmin.ts:60,163`ANTES: `Solen2026`. DEPOIS: `Senle# + random hex`.**■ CORRIGIDO CORS-001 MÉDIA****CORS origin * → `CORS_ORIGIN` env var**■ `server.ts:14-17`ANTES: `*`. DEPOIS: `process.env.CORS_ORIGIN`.**■ CORRIGIDO ISOLATION-002 MÉDIA****Alunos unassigned global → filtra instituição**■ `professor.ts:69-80`ANTES: sem filtro. DEPOIS: `institutionId/instituicao` para não-ADMIN.**■ CORRIGIDO AUTH-002 MÉDIA****Token via query string → restrito a templates**■ `auth.ts:12-15`ANTES: qualquer rota. DEPOIS: apenas `/admin/templates/`.**■ CORRIGIDO CONFIG-001 BAIXA****Senha padrão 1234 → senha obrigatória no body**■ `admin.ts:84`

ANTES: hardcoded 1234. DEPOIS: campo password obrigatório.

■ CORRIGIDO CONFIG-002 BAIXA**Código invocação 1234 → código aleatório**■ `admin.ts:134`ANTES: 1234. DEPOIS: `Math.floor(1000 + Math.random() * 9000)`.

3. Pontos Fortes do Código

■ validateInstitution (security.ts)

Hook preHandler valida turmalId, disciplinaId e targetUserId contra a instituição do usuário em todas as rotas admin/professor/quests.

■ validateTenantStatus (security.ts)

Bloqueia usuários de instituições INADIMPLENTE/CANCELADO. ADMINS são isentos corretamente.

■ Filtros de listagem admin

GET /masters, /students, /turmas, /disciplinas filtram corretamente por instituicao.

■ SuperAdmin autenticação

Todas as rotas exigem role ADMIN via hook dedicado com authenticate.

■ Professor turmaDisciplinas

Rotas filtram por turmaDisciplinas.some(professorId) — professor só vê suas turmas.

■ Bounty posse

/seen e /response verificam bug.userId !== request.user.id.

■ bcrypt em todas as senhas

Professores, arquitetos e agora alunos — todos hashados com bcrypt cost 10.

■ .env no .gitignore

Arquivo listado tanto no root quanto no backend/.gitignore.

■ JWT_SECRET validação startup

Servidor recusa iniciar se JWT_SECRET não estiver definido.

■ Webhook autenticado

WEBHOOK_SECRET validado via header antes de processar.

■ Escape HTML em e-mails

escapeHtml() aplicado a todos os campos de input antes de injetar no template.

■ Senhas aleatórias

Arquitetos recebem Senle#XXXX, turmas recebem código 4-dígito aleatório.

4. Conclusão

A auditoria de segurança do Collegium identificou e verificou a correção de **15 vulnerabilidades** distribuídas em 5 categorias (Chaves Expostas, Permissão, IDOR, Isolamento de Dados, XSS), com severidades variando de Crítica a Baixa.

Todas as correções foram aplicadas e verificadas manualmente no código-fonte ao longo de 3 iterações. Os principais padrões de correção incluem:

- Remoção de secrets hardcoded com validação de startup
- Hash bcrypt em todas as senhas (incluindo alunos)
- Verificação de posse (isSameInst) em operações de reatribuição
- Filtro de instituição em queries de listagem
- Escape de HTML em templates de e-mail
- Autenticação de webhooks via secret compartilhado
- Geração de senhas/códigos aleatórios em vez de defaults

Recomendação: Manter■■■ (esta) auditoria como referência e repetir o processo a cada release significativa. Considere adicionar testes automatizados de segurança (IDOR, auth bypass) ao pipeline de CI/CD.